INSPECCO × KRIPTARIUM

SAFETY 4.0 BOOTCAMP

Laboratuvar Föyleri — Standart Pompa Yangın Pompa Seti Sürümü

Tüm laboratuvarlar, SAMİB üyesi Standart Pompa'nın NFPA 20'ye uygun yangın pompa setine uyarlanmıştır: elektrikli ana pompa + dizel yedek pompa + jokey pompası · her pompaya ayrı kilitli kumanda panosu · bina otomasyonuna kuru kontak çıkışları · planlanan **S Plus Connect** uzaktan izleme kutusu (4G / bulut).

> **Bu makineyi farklı kılan:** Şişeleme hattında ve PaketPro'da güvenli durum "makine durur"dur. Yangın pompasında güvenli durum **"pompa çalışır ve basınç sağlanır"**dır. Saldırganın hedefi bu yüzden makineyi çalıştırmak değil, yangın anında **susturmaktır**.

LAB 1 · Safety Architecture — Çıktı: Safety Function Map

LAB 2 · IEC 62443 Mini Workshop — Çıktı: Zone / Conduit Diagram

LAB 3 · Threat & Risk + Risk Matrix — Çıktı: Risk Register

LAB 4 · Secure Remote Access — Çıktı: Secure Architecture

LAB 5 · SBOM / CVE / Patch — Çıktı: Vulnerability Decision

LAB 6 · CRA Incident Simulation — Çıktı: Incident Workflow

LAB 7 · AI Safety Challenge — Çıktı: AI Fail-Safe Decision

MACHINE STARTER PACK — Varlık Envanteri (EP 01) · Evidence Pack 15 başlık · RACI + 90 günlük plan

Makine bilgileri Standart Pompa genel ürün kataloğundan (Rev.12, Ekim 2023) alınmıştır. Pano içinde PLC / elektronik kontrol kartı bulunup bulunmadığı ve S Plus Connect kutusu, firmadan doğrulanması gereken varsayımlardır.

Bu föyler bir eğitim çıktısıdır; resmî denetim, uygunluk değerlendirmesi veya belgelendirme değildir ve CE/mevzuat uygunluğu garantisi vermez. Doldurduğunuz föyler gün sonunda Machine Starter Pack'inizi oluşturur ve Safety 4.0 Workspace'te yaşamaya devam eder.

LABORATUVAR 1 · STANDART POMPA · YANGIN POMPA SETİ

Safety Architecture

Çıktı: Safety Function Map

Ad Soyad *Nisa Güven* | Grup | Tarih *02.11.2026*

Yangın pompası bağlamı: Sprinkler hattında basınç düşünce basınç anahtarı kilitli kumanda panosuna sinyal verir; pano önce jokey, sonra ana elektrikli pompayı, gerekirse dizel yedek pompayı başlatır. Panonun kuru kontakları bina otomasyonuna gider ve planlanan S Plus Connect kutusu bu kontakları okuyup 4G ile buluta taşıyacak — sorular oraya gidecek.

Kavram: Emniyet fonksiyonu, insanı koruyan fonksiyondur ve ayrı bir safety yolunda yaşar. Gerekli güvenilirliği (PLr/SIL) riskle orantılıdır — ve bu güvenilirlik, dijital bir konfigürasyona bağlıdır.



Görev — sırayla cevaplayın

1. **Bu makinede tehlike nedir? İnsan neyden zarar görür?**

   Asıl tehlike yangındır: pompa basınç sağlayamazsa sprinkler, yangın dolabı ve hidrantlara su gitmez; binadakiler alev, ısı ve duman zehirlenmesiyle zarar görür, itfaiye müdahalesi de zayıflar. Pompa odasında ikincil tehlikeler: dönen kaplin/mil, elektrik çarpması, dizel egzozu ve sıcak yüzeyler.

2. **Safety function (emniyet fonksiyonu) hangisidir?**

   "Sistem basıncı ayar değerinin altına düştüğünde ana pompayı otomatik başlat; basınç yine sağlanamazsa dizel yedek pompayı başlat ve basınç normale dönse bile minimum çalışma süresi (elektrikli ≥10 dk, dizel ≥30 dk) dolmadan durdurma."

3. **Safety-related control system nerede? Şemada işaretleyin.**

   Şemadaki kırmızı (alt) yol: basınç anahtarları → her pompanın ayrı, kilitli kumanda panosu (koruma rölesi, zamanlayıcılar) → kontaktör / dizel start ünitesi. Jokey panosu da bu yola dahildir. İzleme kutusu ve BMS bu yolun DIŞINDADIR.

4. **Normal PLC ile Safety PLC farkı nedir?**

   Bu makinede ayrı bir "Safety PLC" yerine emniyet yolunu kilitli pano ve basınç anahtarları taşır; normal yol ise izleme ve raporlamadır. Fark: normal yol veri üretir/okur, hata yapabilir ve makine yine güvendedir; emniyet yolu ise kendi kendine, ağdan bağımsız çalışmak, kilitlenebilir ayarlara sahip olmak ve arızada bile pompayı çalıştırabilmek (elle elektriksel / elle mekanik yol verme) zorundadır.

5. **PLr / SIL neden var? Bu fonksiyon için neden önemli?**

   Koruma riskle orantılı olmalı. Burada şiddet en üst düzeydir (çok sayıda can kaybı), maruz kalma süreklidir (bina her an dolu olabilir) ve yangında kaçınabilirlik düşüktür. Bu yüzden yüksek güvenilirlik gerekir; yönetmelik ve NFPA 20 bunu yedek pompa, çift basınç anahtarı, bağımsız enerji ve kilitli pano şartlarıyla somutlaştırır. Bu güvenilirlik pano ayarlarına (basınç set değerleri, zamanlayıcılar) bağlıdır — ayar değişirse koruma düşer. (Bugün hesap yapılmadı.)

6. **Safe state (güvenli durum) nedir?**

   "Pompa çalışır ve sistem basıncı korunur." Klasik makinelerin tersine, güvenli durum enerjiyi kesmek değil, vermektir. Bu yüzden ana pompa durursa dizel devreye girer; otomatik başlayan pompa basınç normale dönse bile hemen durmaz.

7 **Safety function hangi dijital bağımlılıklara sahip?**

> Basınç set değerleri (PJSET / P1SET / P2SET), haftalık otomatik test zamanlayıcısı ve selenoid vanası, minimum çalışma zamanlayıcısı, dizel kontrol ünitesi (start denemeleri, akü/şarj), pano otomatik/el seçici durumu, bina otomasyonu bağlantısı ve eklenecek S Plus Connect kutusu ile servis bilgisayarı.

8 **Siber müdahale hangi noktadan bu fonksiyonu bozar?**

> (a) İzleme kutusu ya da BMS panoya yazabiliyorsa: otomatik mod kapatılır veya pompa durdurulur. (b) Set değerleri ve zamanlayıcılar elektronikse ve servis bilgisayarı/USB ile değiştirilebiliyorsa: basınç eşiği düşürülür, haftalık test kapatılır. (c) İzleme verisi sahtelenirse: gerçek arıza "normal" görünür ve yangına kadar fark edilmez.

Bu föyün çıktısı **Safety Function Map** → Evidence Pack **EP 03 Safety Functions** başlığına oturur.

LABORATUVAR 2 · STANDART POMPA · YANGIN POMPA SETİ

IEC 62443 Mini Workshop

Çıktı: Zone / Conduit Diagram

Ad Soyad *Nisa Güven* | Grup | Tarih *02.11.2026*

Kavram: Zone = benzer kritiklikteki cihazları bir bölgeye topla. Conduit = bölgeler arası her geçişe kontrollü bir kapı. 62443'ün maddesini ezberlemiyoruz — mantığını uyguluyoruz.

Görev A — varlıkları bölgelere ayırın

Varlık listesi: Basınç anahtarları · elektrik pompa kumanda panosu · dizel pompa kumanda panosu + dizel kontrol ünitesi · jokey pompa panosu · haftalık test zamanlayıcısı / selenoid vana · S Plus Connect kutusu (4G modem) · bina otomasyon sistemi (BMS) · yangın alarm paneli · S Plus bulut platformu · mobil uygulama · servis teknisyeni dizüstüsü · bayi/servis hesapları

1 Hangi varlıklar aynı bölgede? Bölgeleri adlandırıp gruplandırın.

Z1 · Emniyet	Z2 · İzleme	Z3 · Bina	Z4 · Bulut	Z5 · Servis
Basınç anahtarları, 3 kumanda panosu, dizel kontrol ünitesi, test zamanlayıcısı / selenoid	S Plus Connect kutusu, 4G modem	BMS, yangın alarm paneli	S Plus platformu, mobil uygulama, bildirim servisi	Teknisyen dizüstüsü, bayi/servis hesapları, uzak destek

> Kritiklik sırası Z1 > Z2 > Z3 > Z5 > Z4. Bölge içi güvenilir kabul edilir; bu yüzden internete dokunan hiçbir şey Z1'e konmaz.

2 Kumanda panolarını (bu makinenin "Safety PLC"si) hangi bölgeye koydunuz — neden?

> Z1 Emniyet bölgesine, tek başlarına. Hayatı koruyan fonksiyon burada yaşıyor; ağ bağlantısı yok, ayarlar kilitli ve fiziksel erişim anahtarla. İzleme kutusu bile aynı panonun yanında dursa da ayrı bölgededir (Z2), çünkü internete konuşur.

3 Bölgeler arası geçişler (conduit) nerede? Her geçişte ne kontrol edilecek?

Conduit	Ne geçer, hangi yönde	Kontrol
C1 · Z1 → Z2	Kuru kontak durumları (alarm, pompa çalışıyor, test başladı, otomatik mod) — sadece Z1'den Z2'ye	Tek yönlü, galvanik izoleli giriş; Z2'den Z1'e hiçbir çıkış/röle kablolanmaz (yazma yolu fiziksel olarak yok)
C2 · Z1 → Z3	Aynı kuru kontaklar, BMS'e bilgi amaçlı	Tek yönlü; katalog gereği BMS'ten pompa çalıştırma/durdurma yok
C3 · Z2 → Z4	Telemetri ve olay kayıtları	Sadece dışarı giden TLS bağlantısı, cihaz sertifikası, sabit hedef adres; gelen bağlantı kapalı
C4 · Z5 → Z2 / Z4	Servis erişimi, yazılım güncellemesi	Jump server + VPN + MFA + kişisel hesap + oturum kaydı; sadece imzalı güncelleme
C5 · Z5 → Z1	Ayar değişikliği, bakım	Sadece fiziksel: pano anahtarı, iş emri, değişiklik kaydı, sonrasında elle test

Görev B — uzak erişim kararı (6 satır)

Karar	Seçenekler	Seçiminiz + nedeni
Aracı?	Doğrudan / Jump server	**Jump server.** Kutu internetten doğrudan erişilebilir olmaz; tüm servis erişimi tek, izlenen bir noktadan geçer.
Tünel?	Açık / VPN	**VPN.** Trafik şifreli; 4G modem üzerinde açık port bırakılmaz.

Kimlik?	Parola / MFA	**MFA.** 114 servis noktasında çok teknisyen var; tek bir sızan parola yetmemeli.
Hesap?	Paylaşılan / Kişisel	**Kişisel.** Her teknisyen ve bayi kendi hesabıyla; kim neyi yaptı izlenebilir, ayrılan kişinin hesabı kapatılır.
Kayıt?	Yok / Tam oturum kaydı	**Tam oturum kaydı.** Olayda kanıt (CRA) ve bina sahibi/sigorta için iz.
Zamanlama?	Sürekli açık / Varsayılan kapalı	**Varsayılan kapalı.** Servis talebi açılınca süre sınırlı açılır; telemetri (C3) bundan bağımsız çalışır.

Bu föyün çıktısı **Zone / Conduit Diagram** → Evidence Pack **EP 05 Zone & Conduit** başlığına oturur.

LABORATUVAR 3 · STANDART POMPA · YANGIN POMPA SETİ

Threat & Risk + Risk Matrix

Çıktı: Risk Register

Ad Soyad *Nisa Güven* | Grup | Tarih *02.11.2026*

Kavram: Senaryo beş parçadır: kim → hangi kapı → ne yapar → zincir → FİZİKSEL sonuç. Skor = L × S × E (her biri 1–3). Kural: S=3 ise skor düşük olsa bile senaryo öne alınır — insana zarar görünür kalır.

Yangın pompasının kapıları (ipucu): S Plus Connect 4G modemi · bulut/mobil uygulama hesapları · servis dizüstüsü ve USB · kilitli ama anahtarı paylaşılan pano · BMS bağlantısı · kutu yazılım güncellemesi — fiziksel sonuç adayları: yangında pompanın kalkmaması, yetersiz basınç, arızanın yangına kadar gizli kalması.

Görev — üç senaryo kurun ve puanlayın

Senaryo (kim → kapı → zincir → fiziksel sonuç)	L	S	E	Skor	Öncelik
Fırsatçı dış: İnternette açık port tarayan bot → varsayılan parolası değiştirilmemiş S Plus Connect modemi → kutu panoya yazabilecek şekilde kablolanmışsa otomatik mod kapatılır / pompa "dur" komutu alır → yangında pompa kalkmaz, sprinkler basınçsız kalır → can kaybı	**2**	**3**	**3**	**18**	**Kritik**
Tedarik zinciri: Kutu yazılım tedarikçisi ele geçirilir → imzasız güncelleme tüm filoya yüklenir → kutular sürekli "normal" gönderir, gerçek akü/start arızası gizlenir → bakım yapılmaz, yangında dizel pompa çalışmaz → can kaybı	**1**	**3**	**2**	**6**	**Orta → S=3, öne alınır**
Meraklı içeriden: Sık çalışan jokey pompadan rahatsız olan bina görevlisi → paylaşılan pano anahtarı / servis dizüstüsü → basınç set değeri düşürülür veya haftalık test kapatılır → arıza fark edilmez, yangında ana pompa geç ya da yetersiz basınçla devreye girer → yangın büyür	**2**	**3**	**1**	**6**	**Orta → S=3, öne alınır**

Kritik 18–27 · **Yüksek** 9–17 · **Orta** 4–8 · **Düşük** 1–3 · Puanlar örnek tahmindir.

1 **En yüksek öncelikli senaryonuz hangisi? Bir cümleyle: neden bu?**

> 1. senaryo (skor 18): internete açık tek bir kapı, hiçbir hedefli çaba gerektirmeden doğrudan hayat kurtaran fonksiyona dokunabiliyor — çözümü de tasarımda: izleme kutusunun panoya yazma yolu fiziksel olarak olmamalı.

2 **S=3 olup skoru düşük kalan senaryonuz var mı? Nasıl görünür kılacaksınız?**

> Evet, 2. ve 3. senaryolar (skor 6). Risk Register'da S=3 bayrağıyla en üste taşınır ve her birine sahip atanır: 2. için imzalı güncelleme + "veri gelmezse/şüpheliyse alarm" kuralı (sessizlik de alarmdır); 3. için set değeri değişikliğinin buluta olay olarak düşmesi, kişisel pano anahtarı ve haftalık testin yapılmadığının otomatik raporlanması.

Altın kural: Zincir "veri çalındı" ile bitiyorsa emniyet bulgusu değildir — bir adım daha gidin: bu, binadaki insana ne yapar?

Bu föyün çıktısı **Risk Register** → Evidence Pack **EP 04 Risk Assessment** başlığına oturur.

LABORATUVAR 4 · STANDART POMPA · YANGIN POMPA SETİ

Secure Remote Access

Çıktı: Secure Architecture

Ad Soyad *Nisa Güven* | Grup | Tarih *02.11.2026*

Kavram: İki katman, ikisi de şart: erişim güvenliği (girişi zorlaştır: ara nokta, VPN, MFA, kişisel hesap, kayıt, varsayılan kapalı) + emniyet bağımsızlığı (girse bile insan korunur).

Görev A — mevcut → hedef

MEVCUT (ve kaçınılacak "kolay" tasarım)

- Bugün: uzaktan erişim yok; arıza telefonla (444 1 477) bildiriliyor, bakım yılda 3–4 ziyaret.
- Kolay ama yanlış bağlantı: 4G modem internete açık port → teknisyenlerin ortak şifresi → kayıt yok → kutu panoya röle çıkışıyla bağlı ("uzaktan reset" özelliği).
- Sonuç: tek sızan şifre, filodaki tüm yangın pompalarına uzaktan dokunabilir.

HEDEF (beş ilkeyle yeniden tasarlayın)

1. **Ara nokta:** Kutu sadece dışarı bağlanır; servis erişimi jump server üzerinden.
2. **Kişisel hesap:** Her teknisyen/bayi kendi hesabıyla; ortak şifre yok.
3. **MFA:** Bulut ve jump server girişinde ikinci faktör.
4. **Varsayılan kapalı:** Servis erişimi iş emriyle, süre sınırlı açılır.
5. **Oturum kaydı:** Kim, ne zaman, hangi kutuda ne yaptı — kayıt altında.

Kutu → TLS → bulut ← jump server ← VPN ← MFA ← kişisel hesap (kayıtlı)

Görev B — functional safety köprüsü

1 Saldırgan tüm önlemlere rağmen içeri girerse: emniyet fonksiyonu etkilenir mi? Neden?

> Hayır — hedef tasarımda etkilenmez. Kutu panonun kuru kontaklarını yalnızca okur; kutudan panoya hiçbir çıkış kablolanmamıştır. Saldırgan en fazla yanlış bildirim üretebilir ya da izlemeyi kesebilir; basınç anahtarı → pano → pompa zinciri ağdan habersiz çalışmaya devam eder. Bu yüzden "izleme gelmiyor" durumu da ayrıca alarm olarak ele alınır.

2 Emniyet fonksiyonunun kontrol sisteminden (izleme/uzak erişim yolundan) bağımsız çalışması için GEREKSİNİMİ yazın (çözümü değil).

> "Yangın pompalarını başlatma, durdurma, otomatik/el modunu değiştirme ve basınç/zamanlayıcı ayarlarını değiştirme yetkisi yalnızca yerinde, kilitli kumanda panosunda ve basınç anahtarlarında bulunmalıdır. Hiçbir ağ bağlantısı (izleme kutusu, BMS, bulut, servis erişimi) bu fonksiyonları etkileyememeli; izleme sisteminin arızalanması, kapatılması veya ele geçirilmesi pompaların otomatik çalışmasını ve minimum çalışma sürelerini değiştirmemelidir."

Tarafsızlık notu: Bu föy çözüm tasarlatmaz; gereksinimi tanımlatır. Tasarım kararı firmanındır.

Bu föyün çıktısı **Secure Architecture** → Evidence Pack **EP 02 + EP 06** başlığına oturur.

LABORATUVAR 5 · STANDART POMPA · YANGIN POMPA SETİ

SBOM / CVE / Patch

Çıktı: Vulnerability Decision

Ad Soyad *Nisa Güven* | Grup | Tarih *02.11.2026*

Kavram: SBOM = yazılım malzeme listesi · CVE = açığın kayıt no'su · CVSS = ciddiyet (0–10). Bir CVE sizi etkiler mi? Üç şart: bileşen var, sürüm etkileniyor, açık ulaşılabilir.

Verilen zafiyet kaydı

Bileşen	Component X — S Plus Connect kutusunun ağ / firmware kütüphanesi
Sürüm	2.4
CVE	CVE-XXXX-XXXX
Önem	Critical (CVSS 9.8)
Yama	Mevcut

Görev — karar akışı

1. **Bu CVE sizi gerçekten etkiliyor mu? (üç şartı kontrol edin)**

   Var mı: Kutunun SBOM'unda Component X listeleniyor mu? **Sürüm:** Sahadaki kutuların firmware sürümleri buluttan çekilir; 2.4 olanlar etkilenen listesine girer. **Ulaşılabilir mi:** Kutu sadece dışarı bağlanıyor ve gelen portu kapalıysa uzaktan ulaşılabilirlik düşer; ama açığın giden bağlantı/TLS katmanında olup olmadığı kontrol edilir. Üçü de "evet" ise etkileniyoruz. SBOM yoksa bunu bilemeyiz — önce SBOM.

2. **Üretimi (pompayı) hemen durdurur musunuz? Neden / neden değil?**

   Hayır, asla. Yangın pompasını durdurmak güvenli durum değil, güvensiz durumdur. Açık izleme kutusunda; emniyet yolu kutudan bağımsız olduğu için pompa çalışmaya devam eder. Gerekirse sadece kutunun bağlantısı kesilir (izleme geçici durur, servis ziyareti sıklaşır).

3. **Yamayı doğrudan mı uygularsınız, önce test mi? Nerede test?**

   Önce test. Sıra: fabrikadaki test düzeneği (gerçek pano + kutu) → 3–5 pilot saha → kademeli filo dağıtımı. Kutu yalnızca imzalı güncelleme kabul eder; her adımda kutunun yeniden bağlandığı ve alarm sinyallerini doğru okuduğu kontrol edilir.

4. **Bu yama bir safety validation etkiliyor mu? Nasıl anlarsınız?**

   Değişiklik analiziyle: yama yalnızca Z2'deki kutuya dokunuyor ve kutunun panoya yazma yolu yoksa NFPA 20 kabul testi ve emniyet doğrulaması etkilenmez — bu, zone/conduit diyagramı ve kablolama şemasıyla kanıtlanır. Yama pano veya dizel kontrol ünitesi yazılımına dokunsaydı emniyet doğrulaması ve saha kabul testi tekrarlanırdı.

5. **Yama mümkün değilse compensating control (telafi edici önlem) ne olur?**

   Kutunun bağlantısı sadece S Plus bulut adresine izinli hale getirilir (APN / güvenlik duvarı kuralı), gelen trafik tamamen kapatılır, anormal trafik izlenir; olmazsa kutunun bağlantısı kesilip S Plus ziyaretleri geçici olarak sıklaştırılır ve bina sahibine yazılı bilgi verilir. Karar ve gerekçe açık kaydına işlenir.

Bu föyün çıktısı **Vulnerability Decision** → Evidence Pack **EP 09 · 10 · 11** başlığına oturur.

LABORATUVAR 6 · STANDART POMPA · YANGIN POMPA SETİ

CRA Incident Simulation

Çıktı: Incident Workflow

Ad Soyad *Nisa Güven* | Grup | Tarih *02.11.2026*

Senaryo: Saat 10:15. Bir bayi teknisyeninin S Plus servis hesabına gece 03:00'te tanınmayan bir konumdan girilmiş. Bir hastanenin yangın pompa odasındaki izleme ayarları ve bildirim alıcıları değişmiş olabilir; pano ayarlarının etkilenip etkilenmediği henüz doğrulanmadı. Pompalar çalışır durumda. Ürün güvenliği nöbetçisi sizsiniz.

Kavram: Bir olayda en değerli iki şey zaman ve kanıttır. CRA'nın 24s / 72s / 14 gün yükümlülükleri, iyi bir müdahale akışının doğal kilometre taşlarıdır — ezber değil.

Görev — zaman çizgisini doldurun

1 **10:15 — ilk 15 dk: Kimi ararsınız? İlk üç eyleminiz?**

> Ararım: hastanenin teknik müdürü / bina sorumlusu, en yakın Standart Pompa servis noktası, ürün güvenliği sorumlusu (A). Eylemler: (1) Bina sorumlusundan pano seçicilerinin OTOMATİK'te ve basıncın normal olduğunu yerinde teyit etmesini iste; (2) ele geçen hesabı askıya al ve aktif oturumlarını sonlandır (silme!); (3) bulut, jump server ve VPN kayıtlarını dondur/kopyala. Pompayı ve kutuyu resetleme.

2 **İlk 2 saat: Emniyet güvende mi — nasıl doğrularsınız? Hangi kanıt korunur? Hangi hesap kapatılır?**

> Emniyet: servis teknisyeni sahada basınç set değerlerini kayıtlı değerlerle karşılaştırır, haftalık test zamanlayıcısını kontrol eder ve elle elektriksel + elle mekanik yol verme testini yapar; pano kilidi ve kurşun mühür kontrol edilir. Kanıt: bulut olay kayıtları, kutu logları, jump server oturum kaydı, VPN/MFA logları, değişen ayarların önceki/sonraki hali, kutunun firmware sürümü. Kapatılanlar: ele geçen kişisel hesap, aynı bayinin diğer hesaplarının parolaları sıfırlanır, şüpheli API anahtarları iptal edilir; aynı hesabın erişebildiği diğer kutular taranır.

3 **24 saat — CRA erken uyarı: Hangi bilgi hazır olmalı?**

> Etkilenen ürün ve sürüm (S Plus Connect + firmware), aktif istismar şüphesi olup olmadığı, olayın kötü niyetli olduğuna dair ilk değerlendirme, ürünün kurulu olduğu AB üyesi ülkeler ve etkilenen kutu sayısı tahmini, alınan ilk önlemler.

4 **72 saat — CRA bildirim: Kök neden, etki, önlem — kim ne yapıyor?**

> Kök neden (ör. oltalama ile çalınan kimlik + MFA atlatma / açık), etki (kaç kutu, hangi ayarlar, emniyet yolunun etkilenmediği kanıtı), düzeltici önlem (MFA politikası, oturum süresi, alarm kuralı). RACI: ürün güvenliği sorumlusu **A**; OT/ürün ekibi ve servis **R**; IT ve hukuk **C**; etkilenen bina sahipleri ve bayiler **I**.

5 **14 gün — son rapor: Hangi loglar/kayıtlar korunmuş olmalı?**

> Jump server tam oturum kayıtları, VPN/MFA giriş logları, bulut denetim logları, kutu olay logları ve firmware sürümleri, saha kontrol tutanağı ve test sonuçları, değişiklik kayıtları (EP 14), yama kayıtları (EP 11), SBOM sürümü (EP 09), müşteri ve otorite yazışmaları.

En sık hata: "Resetleyip devam edelim" — o düğme, kanıtı sonsuza dek siler. Önce emniyet, hemen sonra kanıt.

Bu föyün çıktısı **Incident Workflow** → Evidence Pack **EP 13 Incident Response** başlığına oturur.

LABORATUVAR 7 · STANDART POMPA · YANGIN POMPA SETİ

AI Safety Challenge

Çıktı: AI Fail-Safe Decision

Ad Soyad *Nisa Güven* | Grup | Tarih *02.11.2026*

> **Kavram — Prediction ≠ Safety:** Yapay zekâ bir karar üretir; güvenliği garanti eden mimari YZ'nin dışında tanımlanmalıdır. Araçlar: fail-safe · human override · monitoring · confidence threshold · fallback.

Senaryo: S Plus Connect platformuna YZ'li arıza tahmini eklenmesi planlanıyor — proje aşaması değerlendirmesi yapıyorsunuz. Pano sinyalleri + akü/şarj + start denemeleri + çalışma süreleri → **YZ Modeli** → "Sağlıklı / Bakım gerekli" → servis iş emri önceliği. Model pompayı asla kontrol etmez.

Görev — üç başarısızlıkta güvenli davranış

1 Model yanlış sınıflandırdı: Arızalı pompaya "sağlıklı" dedi. Sistem ne yapmalı? İkinci kontrol / insan onayı var mı?

> Modelin kararı hiçbir zaman gerçek alarmı bastıramaz: panodan gelen alarm, start hatası, akü arızası sinyalleri modelden bağımsız olarak doğrudan servise ve bina sorumlusuna gider. Takvimli S Plus ziyaretleri ve haftalık test kaldırılmaz; model yalnızca iş emirlerini öne çeker, iptal etmez. İkinci kontrol = fiziksel test.

2 Girdi manipüle edildi: Sensör / kutu verisi bozuk ya da sahte. Nasıl fark edilir? Şüpheli girdide ne yapılır?

> Fark etme: veri imzası ve sıra numarası, fiziksel olarak imkânsız değerler (ör. test başladı ama pompa çalışmadı), haftalık testin beklenen saatte gelmemesi, uzun süre hiç değişmeyen "mükemmel" veri. Şüpheli girdide model o kutu için devre dışı kalır, "veri güvenilmez" alarmı servise gider ve o saha en riskli kabul edilip ziyaret planlanır.

3 Confidence düştü: Model "emin değilim" diyor. Eşik ne olmalı? Altında: dur / insana sor / fallback?

> Pilot verisiyle belirlenen bir eşik (ör. %80); altında tahmin "sağlıklı" olarak gösterilmez. Pompa durdurulmaz (durmak güvensiz durum); karar servis teknisyenine sorulur ve kutu için takvimli bakım planına dönülür.

Karar tablosu — AI Fail-Safe Decision

Başarısızlık	Tanımladığınız güvenli davranış (hangi kavramla?)
Model yanlış sınıflandırdı	**Monitoring + fallback:** gerçek pano alarmları modelden bağımsız iletilir; takvimli bakım ve haftalık test sürer. Model iş emrini iptal edemez.
Girdi manipüle edildi	**Fail-safe + monitoring:** veri bütünlüğü kontrolü; şüpheli veride model devre dışı, "veri güvenilmez" alarmı, saha en riskli kabul edilir.
Confidence düştü	**Confidence threshold + human override + fallback:** eşik altında tahmin gösterilmez, teknisyene sorulur, takvimli bakıma dönülür; pompa asla durdurulmaz.

Bu föyün çıktısı **AI Fail-Safe Decision** → Evidence Pack **EP 03 + EP 15** başlığına oturur.

Varlık Envanteri

Çıktı: EP 01 Asset Inventory

Ad Soyad *Nisa Güven* | Grup | Tarih *03.11.2026*

> **Kavram:** "Görmediğin kapıyı kilitleyemezsin." Korumanın ilk adımı sayımdır — ve sayım hafızayla değil, kategoriyle yapılır. Her kategoride üç kez "başka?" diye sorun.

Sonuç: "Pompa, pano, motor" diye başlayan liste, sistematik sayım sonrası **27 varlık + 6 dış bağlantıya** çıktı; ayrıca 7 hesap ve 6 kritik veri akışı var. 9 varlık emniyet yolunun parçası (Z1).

Kategori	Varlıklar
1 · Donanım (16)	**Z1:** ana elektrikli pompa, dizel yedek pompa, jokey pompa, basınç anahtarları (≥2), elektrik pompa panosu, dizel panosu + kontrol ünitesi, jokey panosu, test zamanlayıcısı + selenoid, akü 1/2 + şarj · **izleme:** debimetre, vana izleme anahtarları · **Z2:** S Plus Connect kutusu, 4G modem/SIM · **Z3:** BMS, yangın alarm paneli · **Z5:** servis dizüstüsü, USB/servis kablosu
2 · Yazılım / firmware (6)	Pano koruma rölesi/kontrolcü yazılımı, dizel kontrol ünitesi firmware, kutu firmware + işletim sistemi, bulut platformu, mobil uygulama, servis ayar yazılımı (varsa)
3 · Sertifika / anahtar (5)	Kutu cihaz sertifikası, **güncelleme imza anahtarı** (en kritik), bulut TLS sertifikası, VPN/jump server anahtarları, bildirim servisi anahtarları
4 · Dış bağlantı (6)	Kutu → bulut (4G, sadece dışarı) · pano → BMS (tek yönlü) · servis → jump server → VPN · bulut → mobil bildirim · güncelleme sunucusu → kutu (imzalı) · bulut → bayi paneli
5 · Hesaplar (7)	Bina sahibi, bina teknik personeli, Standart Pompa teknisyeni, bayi teknisyeni, platform yöneticisi, kutu yerel servis hesabı (varsayılan parola olmamalı), pano anahtarı (fiziksel "hesap")
6 · Kritik veri akışı (6)	Alarm/çalışma/otomatik mod · haftalık test sonucu · set değeri değişikliği (sabotaj belirtisi) · firmware güncellemesi · servis oturum kayıtları · müşteri/bina verisi (KVKK)

Pano içi elektronik ve firmware sürümleri firmadan doğrulanacaktır. Ayrıntılı tablo: ekler/01-varlik-envanteri.md

Bir saldırgan, sizin bildiğiniz kapıdan girmez — bilmediğiniz kapıdan girer.

Evidence Pack — 15 Başlık

Durum: Yok / Taslak / Var / Doğrulanmış

> **"Yarın denetçi geldi — masaya hangi dosyaları koyacaksınız?"** Kanıt merdiveni: Beyan → Prosedür → Kayıt → Doğrulanmış kayıt. Hedef: her başlıkta bir basamak yukarı.

EP	Başlık	Bugün (tahmin)	Föylerden sonra	Kaynak	Sıradaki adım
01	Asset Inventory	Yok	Taslak	Starter Pack s.1	Pano içi elektronik ve sürümler
02	Network Architecture	Yok	Taslak	Lab 4	Kablolama şeması
03	Safety Functions	Var	Taslak (güncel)	Lab 1, 7	Siber bağımlılıkları ekle
04	Cyber Risk Assessment	Yok	Taslak	Lab 3	Puanları kalibre et
05	Zone & Conduit	Yok	Taslak	Lab 2	Pilotta doğrula
06	Remote Access Procedure	Yok	Taslak	Lab 2B, 4	Yazılı prosedür
07	User/Role Matrix	Yok	Taslak	Envanter	İzin tablosu
08	Software/Firmware Inv.	Yok	Yok	—	Sürümleri topla
09	SBOM	Yok	Yok (şablon)	Lab 5	Otomatik SBOM üretimi
10	Vulnerability Records	Yok	Taslak	Lab 5	Açık bildirim politikası
11	Patch/Update Records	Yok	Yok	Lab 5	İmzalı güncelleme
12	Backup & Restore	Yok	Yok	—	Pano ayar yedeği
13	Incident Response	Yok	Taslak	Lab 6	Tatbikat
14	Change Management	Yok	Yok	—	Ayar değişikliği formu
15	Verification/Test	Var (NFPA 20)	Var	Katalog	Sızma testi ekle

Özet: Bugün 2 başlık "Var"; föylerle 9 başlık "Taslak"a çıktı; 5 başlık (08, 09, 11, 12, 14) ürün henüz olmadığı için "Yok".

Safety 4.0 RACI + 90 Günlük Plan

"Kim?" sorusu

> **Kavram:** R = yapan · A = nihai sorumlu (tek) · C = görüşü alınan · I = bilgilendirilen. A'sı boş satır = sahipsiz iş → 90 günlük plana girer.

Görev	İş	Tasarım	OT	IT	Safety	Servis	Yönetim
Asset inventory	C	R	R	C	C	C	A
Remote access	I	C	R	R	C	C	A
Patch / update	I	R	C	C	C	R	A
Safety change (pano ayarı)	I	C	C	I	R	C	A
Incident	C	C	R	R	C	R	A
Risk assessment	C	R	R	C	R	C	A
SBOM ve açık yönetimi	I	R	C	R	I	I	A
Abonelik ve müşteri bildirimi	R	I	I	C	I	R	A
CRA otorite bildirimi	I	C	C	C	C	I	A

90 günlük plan

Hafta	İş	EP
1–2	Ürün güvenliği sorumlusunu ata, RACI'yi imzalat	07
1–3	Pano tiplerinin iç yapısını ve firmware sürümlerini topla	01, 08
2–4	"Sadece okur" tasarım gereksinimi ve kablolama şeması	02, 05
3–6	Uzak erişim prosedürü (jump server, MFA, kişisel hesap, kayıt)	06
4–8	Kutu prototipi + otomatik SBOM	09
5–8	Pano ayar değişikliği iş emri ve kayıt formu, ayar yedeği	12, 14
6–9	Açık bildirim politikasını yayımla	10
8–10	Olay müdahale tatbikatı (Lab 6 senaryosu)	13
9–12	3–5 pilot sahada kurulum ve doğrulama	02, 05, 15
12–13	Evidence Pack durumunu yeniden değerlendir	Tümü

> **90 gün hedefi:** EP 01, 02, 05, 06, 07, 13 "Var"; EP 09, 10, 14 en az "Taslak".

Referanslar: ISO 12100/13849, IEC 62061/61508, IEC 62443, ISO/IEC 42001, Makine Tüzüğü (AB) 2023/1230, CRA.